Quality Assurance & Security Report

Fooducia™ — Customer App, Admin Console & API

Prepared by Kiwik™ · Engineering & Security · 13 October 2026
Scope: end-to-end functional retest, infrastructure migration, and OWASP-aligned security review

Legend: PASS verified working FIXED corrected in this cycle OPEN needs a decision/action N/A not applicable by design

1. Reported Bug Tracker — 22 items (12 Oct testing)

Issues logged during end-to-end testing. The majority share a single root cause: the application was displaying **fake data** — either the API's built-in seed catalogue (during a database outage) or the in-app mock server (shipped by every over-the-air update).

#	REPORTED ISSUE	ROOT CAUSE / EXPLANATION	STATUS
1	8 communities in admin, 3 in app	API served seed data (seed contains 3) during a DB outage	FIXED
2	No WhatsApp OTP; 123456 works	ALLOW_DEV_OTP=1 suppresses real sends; WhatsApp confirmed working when off	CONFIG
3	Slow after OTP submit	Render free-tier cold start (~50s); warm latency ~1s	FIXED
4	Verify returns to "What's your number?"	Session-refresh budget 5.4s vs 50s cold start → app renders logged-out	FIXED
5	Asked for OTP again	Same refresh-budget cause	FIXED
6	Sent to community select, not dashboard	Same refresh-budget cause	FIXED
7	Product images changed "on their own"	Seed/mock catalogue (51/54 images differ; mock uses stock photos)	FIXED
8	Non-veg items in veg section	Seed/mock categories differ from real data	FIXED
9	Non-veg section empty	3 missing products are all non-veg (absent from seed)	FIXED
10	Cart item names in English not Telugu	Cart response omitted the multi-language names map	FIXED
11	Checkout names in English	Same cause as #10	FIXED
12	Order placed without payment taken	Mock payment simulator (always succeeds) — not the real code	NOT REAL
13	Order-tracking names in English	Seed-mode; tracking endpoint already sends names	FIXED
14	Wallet credited without bank debit	Mock simulator — real code rejects unverified credit	NOT REAL
15	Cancel-requests count disappears	Count was computed client-side from the filtered list	FIXED
16	Purpose of "Past delivery day" tab	Not a defect — lists open orders past their delivery date	EXPLAINED
17	2 orders today missing from admin	Persistence disabled → orders held in memory, lost on restart	FIXED
18	Past-delivery count disappears	Client-side counting	FIXED
19	Procurement number logs in as customer	Staff list empty while in seed mode	FIXED
20	GST not in order total	GST was included; the line was missing on old bundles; rate also corrected	FIXED
21	Wallet toggle on by default	Genuine default state (useState true)	OPEN

22	Cannot log in as staff roles	Staff list empty in seed mode	FIXED

2. Root-Cause Infrastructure Defects

The underlying faults that produced the symptoms above — and the reason bugs appeared to “return” after server-side fixes.

DEFECT	EXPLANATION	WHY IT OCCURRED	STATUS
API served the seed shop	On DB failure the API answered 200 from built-in seed instead of failing	boot() attempted the DB connection only once; a sleeping free-tier instance fails that first attempt	FIXED
Empty database served as healthy	A reachable-but-empty DB kept seed categories and reported “healthy”	loadAll() only threw on failure, not on empty; hydrate() keeps seed when given nothing	FIXED
App ran on mock data	Every OTA shipped a fully mocked application to testers	eas update reads the EAS environment (not eas.json); mocks flag was absent and defaulted ON	FIXED
Stale data persisted on phones	Devices kept showing seed data after the server recovered	API sent an ETag but no Cache-Control; Android cached responses heuristically	FIXED
Schema change took production down	Adding DB columns broke hydration → degraded mode (~25 min)	Deploy runs prisma generate but no migration; columns applied after the push	FIXED

> **Resilience added:** the API now refuses to serve fake data (returns 503 while the database is unavailable), retries the connection in the background, and **heals itself** the moment the database returns — proven against a simulated dead-then-recovering database with no restart and no human intervention.

3. Performance

ISSUE	ROOT CAUSE / EXPLANATION	STATUS
Application lag / heavy home screen	Product images were delivered as PNG instead of WebP (952 KB vs 77 KB at 960px — ~12×)	FIXED
Thumbnails briefly blank on first visit	Image CDN generates each resized variant on first request (one-time)	N/A

4. Security Review — Findings & Fixes

OWASP-aligned review against the live application (authorised). The core commerce and authentication paths held; the items below were identified and addressed.

FINDING	EXPLANATION	WHY IT OCCURRED	STATUS
Login OTP generated with Math.random()	A login code drawn from a predictable (recoverable) pseudo-random generator	Convenience default never revisited	FIXED
OTP response enumeration oracle	Response returned the fixed dev code for allowlisted numbers, revealing which numbers are test accounts	Added for tester convenience; became an oracle	FIXED
Image upload trusted declared type	contentType accepted without verifying the file's actual bytes	Whitelist-only validation	FIXED
proxy-addr CVE (critical)	Dependency mis-parses IPv4-mapped IPv6 → client-IP spoof could bypass per-IP rate limits	Transitive via Express; no version override	FIXED
Produce taxed at 10%	Customers overcharged GST on nil-rated fresh produce	Set from admin console (shared token) on 12 Oct	FIXED
No anti-virus on uploads	Uploaded files are not malware-scanned	Never built (low current exposure)	OPEN
Session revocation is process-local	A signed-out token can return after a server restart	In-memory session store	OPEN
Shared ADMIN_TOKEN	A single guessable-default admin credential	Interim auth before Google SSO	OPEN

5. Security — Verified Clean (no change required)

AREA	RESULT / EVIDENCE	STATUS
Transport (TLS/HSTS)	TLS 1.3, HTTP→HTTPS 301, HSTS with includeSubDomains	PASS
Security HTTP headers	Full CSP, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, COOP/CORP	PASS
User enumeration	Identical responses for existing vs non-existent numbers	PASS
Vertical access control	Signed-in customer receives 403 on every admin endpoint	PASS
Horizontal access control	Another customer's order returns 404 (existence not confirmed)	PASS
SQL / NoSQL / ORM injection	Parameterised via Prisma; probes treated as text; edge-blocked	PASS
Cross-site scripting (reflected/DOM)	JSON-only API; no innerHTML/eval/dangerouslySetInnerHTML sinks	PASS
Price / quantity tampering	Server authoritative — client-supplied price ignored	PASS
Payment forgery	Forged signature → SIGNATURE_INVALID; balance unchanged	PASS
CSRF	Not applicable — Bearer tokens in header, no cookies	PASS
Session-token randomness	CSPRNG, ~119 bits of entropy	PASS
CORS	Arbitrary origin denied; only allowlisted origins reflected	PASS
Open redirect / parameter pollution / web messaging	No input-built redirects; repeated params rejected; no postMessage surface	PASS
Brute-force protection	Layered OTP limits (≈15 guesses / 15 min against 10^6 space)	PASS
AI endpoint anti-automation	Paid endpoints rate-limited (plan 10, identify 15 per 5 min / IP)	PASS

6. Infrastructure & Cloudflare Migration

TASK	STATUS
Domains moved to Cloudflare; nameservers switched	FIXED
Website records kept direct to Vercel (grey-cloud)	FIXED
Dedicated API hostname (api.fooducia.in) — proxied, certificate valid	FIXED
Razorpay webhook skip rule (browser-integrity exempt)	FIXED
Cloudflare verified to pass API responses byte-identical	PASS
Edge rate-limiting rule (OTP endpoint)	OPEN
Edge caching of API responses	N/A
Origin lock (shared-secret header)	OPEN

> *Note: edge caching of API responses is deliberately **not** enabled — it would reintroduce the data-staleness fault corrected in Section 2.*

7. Feature Delivered — Itemised Bill (Fees & GST)

CAPABILITY	STATUS
Single pricing function shared by cart preview and committed order	FIXED
Two GST rates (goods 0% for fresh produce, services 18%)	FIXED
Admin “Fees & tax” screen with live ₹500-basket preview	FIXED
Customer app renders fee lines and tax on the bill	FIXED
Order stores an immutable snapshot of the bill agreed to	FIXED

8. Outstanding Actions (Client Decision Required)

ACTION	BENEFIT	PRIORITY
Confirm Google SSO, then disable the shared ADMIN_TOKEN	Removes the last guessable-default credential	High
Upgrade hosting from free tier	Eliminates cold starts, webhook timeouts, and process-local session loss	High
Create the Cloudflare OTP rate-limiting rule	Caps SMS/WhatsApp cost-abuse at the edge	Medium
Decide intended wallet-toggle default (#21)	Confirm whether wallet should apply by default	Medium
Each tester clears app data once	Clears any remaining mocked/cached bundle	Medium
Add anti-virus scanning to uploads (if volume grows)	Defence-in-depth for untrusted uploads	Low